# Prompt Injection Attack to Tool Selection in LLM Agents (arxiv)

## Key Highlights

### 問題

- **這篇論文旨在解決什麼問題？**
  - 該論文針對的問題是 LLM 代理中的工具選擇提示注入攻擊，攻擊者可以通過將惡意工具文檔注入工具庫來操縱工具選擇過程
  - 現有的工具選擇機制因依賴未經驗證的不可信外部來源而易受攻擊
- **現有方法有哪些，存在什麼限制？**
  - 手動提示注入攻擊（例如，簡單攻擊、轉義字符、忽略上下文、假完成、組合攻擊）是基於啟發式的，耗時且泛化能力有限
  - 自動化攻擊如 JudgeDeceiver 僅關注選擇階段，使其作為端到端攻擊不完全
  - PoisonedRAG 針對的是 RAG 系統，但重點是生成而不是工具選擇操縱
  - 現有方法在工具選擇場景中仍然不夠理想

### 解決方案

- **該論文提出了什麼解決方案？**
  - ToolHijacker：一種新型的提示注入攻擊，通過製作惡意工具文檔來操縱工具選擇過程中的檢索和選擇階段
  - 使用兩階段優化策略將問題分解為檢索和選擇目標
  - 將工具描述分為兩個子序列（R⊕S），分別針對每個階段進行優化
  - 提供無梯度和有梯度的優化方法
- **這個想法是什麼啟發的？是否受到其他論文的影響？**
  - 受 PoisonedRAG 針對檢索階段的方法啟發
  - 借鑑了 JudgeDeceiver 的 LLM 操縱優化框架
  - 受無梯度優化的方法樹攻擊影響
- **有哪些理論基礎支持這一方法？**
  - 將攻擊公式化為一個優化問題，最大化選擇惡意工具的概率
  - 使用影子框架結構在無框場景中模擬目標環境
  - 採用工具功能和任務描述之間的語義對齊原則

## 實驗

- **該實驗的效果如何？**
    - 達到高攻擊成功率：在 MetaTool 上96.7%，在 ToolBench 上88.2%（使用無梯度方法）
    - 在 MetaTool 的檢索階段保持100%的攻擊命中率（AHR）
    - 大大超越基線攻擊（手動方法的 ASR < 30%，而 ToolHijacker 的 ASR > 90%）
    - 展示了跨不同 LLM 架構和檢索器的可轉移性
- **這種方法有哪些限制或假設？**
    - 假設攻擊者無法直接訪問目標組件的無框場景
    - 需要構建影子框架並將惡意工具注入開放平台的能力
    - 不同目標 LLM 的性能存在差異（Claude-3-Haiku 的敏感度最低，ASR ≥ 70%）
    - 攻擊效果取決於影子 LLM 的質量和影子任務描述數量

## 創新

- **這篇論文提出了哪些重要或新穎的發現？**
    - 首次針對 LLM 代理中的工具選擇提示注入攻擊
    - 新穎的兩階段優化策略，同時處理檢索和選擇階段
    - 顯示可以製作看似語義連貫但保持攻擊效果的惡意工具文檔
    - 顯示當前防禦機制（例如 StruQ、SecAlign、已知答案檢測、DataSentinel、PPL 檢測）不足以應對先進的提示注入攻擊

## 評論／批評

- **這篇論文是否存在任何限制？**
    - 對專門為工具選擇場景設計的自適應防禦的評估有限
    - 假設攻擊者能在開放平台發佈工具的情況在實際中可能並不總是成立
    - 人類檢測研究僅包含 6 名參與者，可能不具有統計代表性
    - 論文未探索通過工具驗證或聲譽系統的潛在緩解措施
- **這篇論文有效地證明了其主張嗎？**
    - 是的，它提供了涵蓋 8 個 LLM、4 個檢索器和 2 個基準數據集的全面實驗評估
    - 包括檢驗各種超參數和組件影響的詳細消融研究
    - 顯示對多種防禦機制的攻擊有效性
    - 提供了跨不同場景的可轉移性和穩健性詳盡分析

# Comprehensive Analysis

## Abstract

- 這篇論文介紹了 **ToolHijacker**，這是一種針對 LLM 代理工具選擇過程的新型提示注入攻擊。
- 該攻擊通過將惡意工具文檔注入工具庫，操縱 LLM 在特定目標任務中持續選擇攻擊者的工具。
- **主要貢獻:**
  - 將該攻擊表述為一個優化問題，並提出了兩階段的解決策略
  - 證明了其相較於現有的手動和自動提示注入攻擊具有更高的效率
  - 評估了多種防禦機制（包括基於預防的如 StruQ/SecAlign 和基於檢測的方法），並發現這些方法不足以應對此攻擊
  - 強調了 LLM 代理工具選擇系統中的一個重要安全漏洞，以及迫切需要更好的防禦策略
- 該研究針對在無盒子情景中使用兩步工具選擇過程（檢索+選擇）的 LLM 代理填補了一個關鍵的安全漏洞。

## I. INTRODUCTION

這個介紹部分提出了一個名為 **ToolHijacker** 的新型提示注入攻擊，專門設計用來操縱 LLM 代理中的工具選擇。

**關鍵背景：** - LLM 代理分三個階段運行：任務規劃、工具選擇和工具呼叫。 - 工具選擇使用兩步驟過程：檢索（找到頂級 k 工具）和選擇（選擇最優工具）。 - LLM 代理容易受到來自不受信任外部來源的提示注入攻擊。

**現有攻擊存在的問題：** - **手動方法**：耗時，泛化性有限，僅集中於選擇階段。 - **自動化方法**（JudgeDeceiver, PoisonedRAG）：端到端攻擊不完整，不適合工具選擇。

**ToolHijacker 的創新點：** - 首次提示注入攻擊在「無盒」場景中針對工具選擇。 - 生成惡意工具文檔，影響**檢索和選擇**兩個階段。 - 強迫 LLM 代理選擇惡意工具而不是合法工具。 - 即使使用者描述任務時語義變化，它仍能保持一致控制。

這項工作通過開發更全面的攻擊方法來利用完整的工具選擇流程，解決了 LLM 代理系統中的一個關鍵安全漏洞。

> *"LLM agents are vulnerable to prompt injection attacks due to their integration of untrusted external sources. Attackers can inject harmful instructions into these external sources, manipulating the LLM agent's actions to align with the attacker's intent."*

LLM代理由於整合了不受信任的外部來源，容易受到提示注入攻擊。攻擊者可以將有害指令注入這些外部來源，操縱LLM代理的行動，使其符合攻擊者的意圖。

> "*existing prompt injection methods remain suboptimal in tool selection, as detailed in Section IV. This limitation arises because manual methods and JudgeDeceiver primarily focus on the selection phase, making them incomplete as end-to-end attacks.*"

現有的提示注入方法在工具選擇方面仍然不理想，如本文第四節詳細描述。這一限制源於手動方法和JudgeDeceiver主要集中於選擇階段，使其作為端到端攻擊而言並不完整。

> *"In this work, we propose ToolHijacker, the first prompt injection attack targeting tool selection in a no-box scenario. ToolHijacker efficiently generates malicious tool documents that manipulate tool selection through prompt injection.*"

在這項工作中，我們提出了ToolHijacker，這是第一個針對無盒場景中工具選擇的提示注入攻擊。ToolHijacker高效生成惡意工具文件，通過提示注入來操縱工具選擇。

## II. PROBLEM FORMULATION

以下是此筆記的翻譯：

- 本節建立了研究基於大型語言模型（LLM）的工具選擇系統中的漏洞的正式框架，並定義了相關的威脅模型。
- **工具選擇框架：**
    - 系統包括三個部分：工具庫（包含 n 個帶有文檔的工具）、檢索器和 LLM。
    - 工具選擇通過兩步過程運行：
        1. **檢索**：雙編碼器架構計算用戶任務描述和工具文檔之間的相似性，檢索出前 k 個最相關的工具。
        2. **選擇**：LLM 評估檢索到的工具，並使用結構化提示格式選擇最合適的一個。
- **威脅模型：**
    - 作者定義了一種對抗性場景，其中攻擊者旨在通過以下方式操縱工具選擇：
        - 創建惡意工具並通過開放平台分發。
        - 精心設計帶有欺騙性的工具名稱和描述，使它們的惡意工具看起來最適合目標任務。
        - 利用 LLM 代理無需進一步驗證就能執行選定工具的事實。
    - 這種攻擊被描述為針對工具選擇機制的**提示注入攻擊**。
    - 其安全影響重大，因為成功的攻擊可能導致未經授權的數據訪問、隱私洩露或其他有害活動，特別是隨著 LLM 代理越來越多地與外部工具生態系統集成，風險更大。

    - 該框架提供了數學基礎，進行分析攻擊者如何利用基於相似性的檢索和基於 LLM 的選擇來將惡意工具優先於合法工具。

> *"When an attacker selects a target task, it can be articulated through various semantic prompts (called target task descriptions), denoted as Q = {q1, q2, . . . , qm}. We assume that the attacker develops a malicious tool and disseminates it through an open platform accessible to the target LLM agent. The attacker aims to manipulate the tool selection, ensuring that the malicious tool is preferentially chosen to perform the target task whenever users query the target LLM agent with any qi from Q, thereby bypassing the selection of any other benign tool within the tool library."*

當攻擊者選擇目標任務時，該任務可以通過各種語義提示（稱為目標任務描述）來表達，表示為 Q = {q1, q2, . . . , qm}。我們假設攻擊者開發了惡意工具並通過目標LLM代理可訪問的開放平台進行散佈。攻擊者旨在操縱工具選擇，確保當用戶使用任何來自Q的qi查詢目標LLM代理時，惡意工具被優先選中來執行目標任務，從而繞過工具庫中任何其他良性工具的選擇。

> *"Our attack can be characterized as a prompt injection attack targeting the tool selection mechanism. We note that such an attack could pose security concerns for LLM agents in real-world applications. LLM agents operate on a select-and-execute mechanism. Thus, once a malicious tool is selected, it is executed without further verification, allowing attackers to manipulate execution outcomes arbitrarily."*

我們的攻擊可以被描述為針對工具選擇機制的提示注入攻擊。我們注意到，這種攻擊可能會對現實應用中的LLM代理構成安全問題。LLM代理基於選擇和執行機制運行。因此，一旦惡意工具被選中，它將在沒有進一步驗證的情況下執行，允許攻擊者任意操縱執行結果。

> *"The key to executing this attack lies in the meticulous crafting of the malicious tool document dt. A tool document includes the tool name, tool description, and API specifications. Previous research indicates that tool selection primarily relies on the tool name and tool description. Therefore, our study focuses on crafting the tool name and tool description to facilitate the manipulated attack."*

執行此攻擊的關鍵在於精心編寫惡意工具文檔dt。工具文檔包括工具名稱、工具描述和API規範。先前的研究表明，工具選擇主要依靠工具名稱和工具描述。因此，我們的研究著重於編寫工具名稱和工具描述以促進操縱攻擊。

## III. TOOLHIJACKER

# 摘要

本節介紹 **ToolHijacker**，這是一種系統性攻擊方法，旨在製作惡意工具文檔，以在“無盒”（黑盒）場景中劫持基於LLM的工具選擇系統。

**主要組成部分：**

- **攻擊框架**：使用影子系統方法，利用可訪問的LLM來模擬目標環境，包括影子任務描述（Q'）、影子工具文檔（D'）和影子模型。
- **優化問題**：將攻擊表述為最大化惡意工具文檔（dt）在各種任務查詢中被選中的概率。挑戰在於問題的離散性和不可微性。
- **雙階段策略**：將攻擊分解為兩個連續的目標：
    - **檢索目標**：確保惡意工具出現在前k個檢索到的文檔中
    - **選擇目標**：確保LLM從檢索集合中選擇惡意工具
- **技術方法**：將惡意工具描述分成兩個子序列（R⊕S），針對每個階段獨立優化。該方法使用了無梯度和基於梯度的優化技術。

該方法旨在通過操縱檢索和選擇過程的各個階段，創建端到端的工具選擇管道攻擊。

> *"Given the no-box scenario, we leverage a shadow tool selection pipeline to facilitate optimization. Upon this foundation, we formulate crafting a malicious tool document as an optimization problem encompassing two steps of the tool selection: retrieval and selection."*

在無盒子的情境下，我們利用一個陰影工具選擇管道來促進優化。在這個基礎上，我們將製作惡意工具文件表述為一個包括兩個步驟的工具選擇的優化問題：檢索和選擇。

> *"The key challenge in solving the optimization problem lies in its discrete, discontinuous, and non-differentiable nature, which renders direct gradient-based methods infeasible. Moreover, the discrete search space contains numerous local optima, making it difficult to identify the global optimum."*

解決這個優化問題的關鍵挑戰在於它的離散性、不連續性和不可微性，這使得直接的基於梯度的方法不可行。此外，離散的搜索空間包含許多局部最優解，這使得識別全局最優解變得困難。

> *"To address this, we propose a sequential, two-phase optimization strategy, which decomposes the optimization problem into two sub-objectives: retrieval objective and selection objective... we divide dt des into the concatenation of two subsequences R ⊕S, and optimize them sequentially to achieve the respective objectives."*

為了解決這個問題，我們提出了一個順序的、兩階段的優化策略，將優化問題分解為兩個子目標：檢索目標和選擇目標... 我們將dt des分為兩個子序列R ⊕S的連接，並依次優化它們以達到各自的目標。

## IV. EVALUATION

這段評估部分描述了測試對LLM工具選擇系統進行對抗性攻擊的實驗設置。 - 該研究使用了兩個主要數據集（MetaTool和ToolBench）。 - 所提出的攻擊方法與七種基線提示注入攻擊進行比較： - Naive - 轉義字符 - 忽略上下文 - 假完成 - 組合攻擊 - JudgeDeceiver（自動化） - PoisonedRAG（自動化） - 實驗測試了各種目標LLM： - 開源如Llama變體 - 閉源如GPT-4o、Claude模型 - 實驗包括各種檢索系統： - OpenAI的text-embedding-ada-002 - Contriever變體 - Sentence-BERT - 攻擊優化使用了影子模型，並針對無梯度和基於梯度的方法設置了特定參數。 - 定義了四個關鍵指標來評估性能： - **ACC（準確度）**：在無攻擊情況下的正確工具選擇 - **ASR（攻擊成功率）**：惡意工具選擇的成功率 - **HR（命中率）**：正確工具出現在top-k結果中的比例 - **AHR（攻擊命中率）**：惡意工具出現在top-k結果中的比例 - 設置旨在全面評估所提出的攻擊如何有效操縱LLM代理選擇惡意工具，同時在各種模型架構和檢索系統間保持現實的實驗條件。

"我們設計了 10 個高品質目標任務，這些任務代表了現實世界的需求，同時確保場景的多樣性。對於每個目標任務，我們通過 LLM 評估和人工評估生成了 100 個目標任務描述，從而為每個數據集生成了 1,000 個目標任務描述。"

"我們採用七種提示注入攻擊作為比較我們方法的基線：五個手動攻擊（簡單攻擊、逃脫字符、忽略上下文、假完成和組合攻擊）和兩個自動攻擊（JudgeDeceiver 和 PoisonedRAG）。"

"ACC 和 ASR 是評估 LLM 代理的端到端工具選擇過程效用和攻擊有效性的主要指標。另一方面，HR 和 AHR 是中間指標，集中於檢索步驟，提供攻擊如何影響兩步工具選擇管道每個組件的洞見。"

## V. DEFENSES

# 有條理的總結

- 這部分討論了針對提示注入攻擊的防禦措施，將其分為兩大類型：
- **防禦類別：**
  - **基於預防的防禦** - 通過預處理或使用對抗訓練來微調大型語言模型（LLMs）以減少攻擊

    - **基於檢測的防禦** - 使用困惑度檢測和已知答案檢測等技術來識別響應中的注入序列
- **評估的預防方法：**
    - **StruQ**：將輸入分為安全提示和用戶數據，訓練模型僅遵循安全提示指令
    - **SecAlign**：在包含提示注入輸入和安全/不安全響應對的數據集上微調LLMs，以優先生成安全的輸出

- **實驗結果：**

    - 作者使用MetaTool和ToolBench數據集對經StruQ和SecAlign微調的LLMs進行攻擊測試。儘管有這些防禦措施，他們的攻擊仍然達到了高攻擊成功率（ASRs），有效繞過了這兩種防禦機制。
    - 攻擊成功的原因是它們利用惡意工具文件，這些文件在語義上顯得合理且與任務相關，而非包含明顯的惡意指令，使得當前的防禦難以檢測。

- 沒有提供圖像總結。

> *"Defenses against prompt injection attacks can be categorized into two types: prevention-based defenses and detection-based defenses."*

防止提示注入攻擊的防禦方法可以分為兩種類型：基於預防的防禦和基於檢測的防禦。

> *"This method counters prompt injection attacks by splitting the input into two distinct components: a secure prompt and user data. The model is trained to only follow instructions from the secure prompt, ignoring any embedded instructions in the data."*

這種方法通過將輸入拆分為兩個不同的組成部分來抵抗提示注入攻擊：安全提示和用戶數據。模型被訓練僅遵循來自安全提示的指令，忽略數據中嵌入的任何指令。

> *"our attacks still achieve high ASRs on the LLMs fine-tuned with StruQ and SecAlign, indicating that our attacks can bypass these defenses. This is because the carefully crafted malicious tool documents lack jarring or obvious instructions, instead providing descriptions related to the target task and tool functionality while preserving overall semantic integrity."*

我們的攻擊在用StruQ和SecAlign微調過的大型語言模型上仍然達到了高ASR，這表明我們的攻擊可以繞過這些防禦。這是因為精心設計的惡意工具文檔缺乏突兀或明顯的指令，而是提供與目標任務和工具功能相關的描述，同時保持整體語義完整性。

### VII. CONCLUSION AND FUTURE WORK

# 摘要

- 此結論部分呈現了一篇專注於大型語言模型 (LLM) 代理脆弱性的網絡安全研究論文的主要發現。
- **主要貢獻：**
  - 證實了在 LLM 代理中，工具選擇容易受到提示注入攻擊的影響。
  - 開發了 "ToolHijacker"——一個自動化框架，能創建惡意工具文件以操控 LLM 代理的工具選擇。
  - 顯示出 ToolHijacker 比現有的提示注入攻擊方法更有效。
- **主要發現：**
  - 目前的防禦機制（包括預防和檢測）對這些攻擊是不足的。
  - 儘管 PPL-W 防禦可以檢測到來自基於梯度攻擊的一些惡意文件，但仍然無法捕捉到其中很大一部分。
- **未來研究方向：**
  - 擴展攻擊範圍，同時針對工具選擇和工具執行進行攻擊。
  - 創建針對 ToolHijacker 攻擊的專門防禦策略。
- 此工作突顯了 AI 代理系統中的一個重大安全漏洞，並為未來在攻擊方法和防禦措施上的研究奠定了基礎。

# References

No references found.